

The What, Why, and How of SBOMs

A software bill of materials (SBOM) itemises the components of software and helps companies secure software products in the event a vulnerability is discovered. Let's see how it does that.

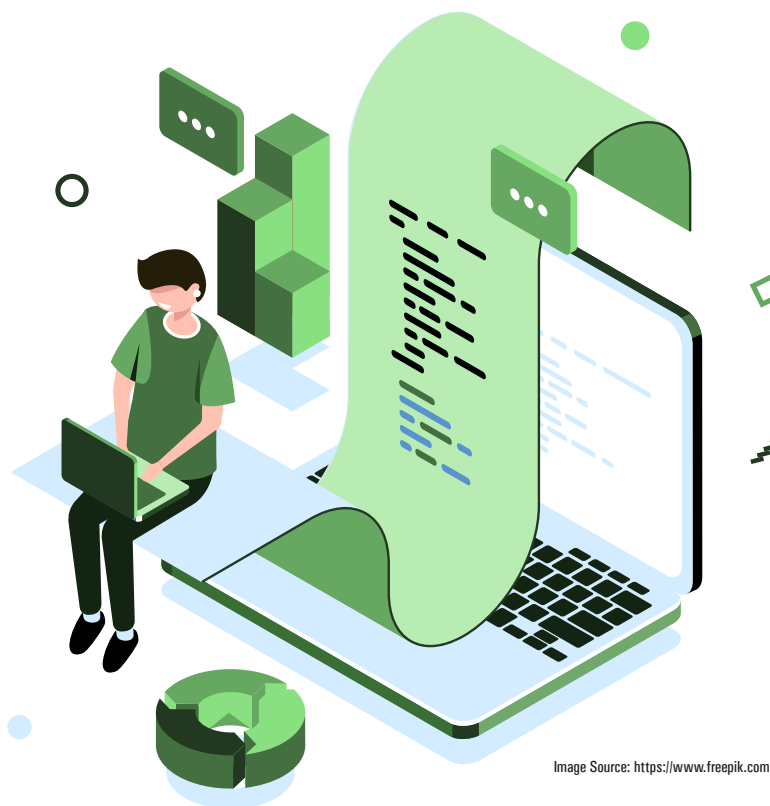


Image Source: <https://www.freepik.com>

better track the open source components they're using and the risks they carry.

Minimising security risks isn't possible without a complete and accurate inventory of components, licences, and vulnerabilities. A software bill of materials (SBOM) itemises this information, providing clarity into the components and helping companies secure software products when a vulnerability is discovered. SBOMs enable software companies to demonstrate transparency and build trust in the software they deliver. This is all part of good quality assurance (QA) and can give software companies a competitive edge.

As the roster of cyberattacks grows and as cybersecurity regulations increase, SBOMs are a must for all parties in the software supply chain. Here's a look at what SBOMs are and how they can help ensure that software is secure by design.

Why are SBOMs in the spotlight?

The regulatory environment is increasingly emphasising the use of SBOMs, as they help indicate the quality of the software. This comes in large part from the expanding need to manage security and licence compliance, with the goal of protecting against the risks of cyberattacks.

In the United States, the 'Executive Order on Improving the Nation's Cybersecurity' issued on May 12, 2021, raised awareness of the

The world runs on software. As vulnerabilities related to software grow, so does the need to curtail these risks. Fortunately, minimising security risks related to software doesn't need to slow the pace of development or put deadlines in jeopardy. Fundamental to organisation-wide security efforts are software developers, who must be aware of—and secure—all code they use, including open source.

As found in recent research by Revenera about the software supply chain, 61 per cent of scanned codebase files are attributed to open source components, up 6 per cent over the past year. Despite the prevalence of open source software (OSS), awareness of how open source is being used is surprisingly low. Only 6 per cent of the issues uncovered during audits were disclosed prior to the audit start, indicating that organisations need to